HUMINT · SOCIAL NETWORK ANALYSIS · CYBERCRIME INVESTIGATION

NocTORnal

Build the graph of actors, personas and the trust between them — where every line of it traces back to an exhibit.

ALPHA · UNAUDITED · NOT CERTIFIED FOR EVIDENTIAL USE

Alembic head 0055 · 1269 tests · AGPL-3.0-or-later

01 — WHAT IT IS FOR

Analysts working organised cybercrime spend most of their time on a question that is social, not technical: who trusts whom, and why?

Which broker vouched for which affiliate.

Which escrow both sides accept.

Which handle here is the same human as that handle there — and how confident is anyone, really.

02 — THE THREE IDEAS EVERYTHING FOLLOWS FROM

A handle is not a person

IDENTITY is what was observed; PERSON is who an analyst assesses them to be. They are joined only by a reversible attribution carrying a confidence.

Collapse them and a wrong call can never be cleanly unwound.

Nothing is a fact

Every attribute and every edge traces to an assertion carrying a source, an Admiralty grading, a confidence, a basis and two timestamps.

Retract a source and the network changes.

Machines propose, analysts dispose

Extractors and inference jobs write to the proposal queue. They cannot write a node or an edge.

A graph that invents links is worse than no graph, because it looks authoritative.

03 — THE PIPELINE

Machines only ever reach the proposal queue.

COLLECTION

Monitored sources
RSS · persona vault · watches

Ingest API
write-only keys, raw kept before parse

Analyst capture
paste · upload · contact block · .eml

→

EXTRACTION

Extractors & parsers

Contact blocks, Received chains, selector normalisers, dedupe.

Holds no writer. It cannot create a node.

Dead letter
Kept with the raw fragment. Nothing is silently dropped.

→

collect.proposal

PROPOSED · ACCEPTED · REJECTED · DISPUTED

ANALYST TRIAGE

Accept, reject or defer. A deferral parks the ambiguous item rather than forcing a yes/no.

An acceptance writes an assertion carrying the machine's rationale.

→

THE MODEL

Assertion ledger
source · Admiralty · confidence · time

Graph
signed, time-bounded, IDENTITY ≠ PERSON

Evidence — WORM
dual-hashed, custody records reads

Lab & deception
bytes never render

Deferred constraint triggers reject any element without an assertion by commit — the guarantee is in the database, not the convention.

04 — FROM THE MODEL TO A FINDING

Projections

`trust` `communication` `financial` `all ties`

Identity plumbing stays out — it would make whichever persona you researched hardest look the most central. Inferred edges render dashed and stay out of the metrics unless a projection opts in.

→

Structural analysis

Betweenness, eigenvector, k-core, Burt's constraint and Leiden communities over igraph's C core.

> Key-player is a set problem, not the top-n by centrality: two brokers who redundantly bridge the same pair are worth less together than either alone.

→

ACH and the report

Hypotheses ranked by inconsistency: the one that survives is the one with the least evidence against it, not the most for it.

The report builds at a target classification, and the redaction is **structural** — nothing above the target is read at any point.

05 — INTEGRATIONS, AND THE ONE FUNCTION THEY ALL PASS

Every outbound path checks classification before it sends.

`can_egress(object, destination)` → Export | SMTP | Jira | Webhook

`AMBER_STRICT / RED → refused + audited`

Email carries a link, not the intel

The subject line carries no intelligence — never the matched keyword, never the handle. The body carries a summary and a deep link; the recipient authenticates and reads it in the platform.

Jira gets work items

Outbound-primary, inbound-status-only. Review a proposal, verify an attribution, rotate a persona credential. Entity names, selectors and assertion content never sync. Jira is never authoritative for intelligence.

Alert hygiene, from the start

Suppression windows, digest batching, quiet hours with a priority-1 override. A platform that emails on every hit gets muted in week two — and then the one alert that mattered is muted too.

06 — THE FIVE-PART ACCESS GATE

Every case-scoped request, as one decision.

1 · VERB

Role grants it

The role is read from the assignment even when it has expired — so an expired analyst keeps the verb and loses the row.

→ 403

2 · ASSIGNMENT

On this case

An unexpired case assignment, checked before existence is revealed.

→ 404, not 403

3 · CLEARANCE

TLP dominates

An ordered lattice, CLEAR through RED, whose order matches the SQL enum.

→ 403

4 · COMPARTMENTS

Read into all

The object's compartments are a subset of the caller's.

→ 403

5 · STEP-UP

MFA is fresh

Merge, export, purge and sample download demand a recent TOTP login.

→ 401, re-auth

ALL FIVE

Proceed

An element is protected by its own labels and its case's — the stricter classification, the union of the compartments.

07 — RUNTIME AND DATA PLANE

CONSOLE

Static analyst UI

Plain HTML, CSS and ES modules under a strict CSP. No build step, no framework. Every value reaching the DOM goes through textContent, and a test enforces it — the UI renders attacker-authored strings all day.

API

FastAPI, /api/v1

About twenty routers, one per subsystem. Rate limit inside, security headers outside, so a 429 still ships a CSP. Errors never stringify a database error to a client.

SYSTEM OF RECORD

Postgres 16 + pgvector

Graph, assertion ledger and audit log in one transactional store, so an inference and its justification commit or fail together. Live updates ride LISTEN/NOTIFY inside the writing transaction.

STORES

MinIO · Redis · SMTP

Three storage domains sharing no credentials or blast radius: evidence, raw, samples. Object lock in COMPLIANCE mode, so not even a root credential can alter an exhibit before retention expires.

08 — THE FOUR INVESTIGATIONS IT WAS BUILT FOR

Ransomware affiliate structure

Twenty handles across three forums and a leak site. Who is the same person, and when did a vouch turn into a rip-off accusation?

> The attribution is reversible, so the call can be withdrawn without losing the observations underneath it.

ENTITIES · GRAPH · TRIAGE · COMMS

Initial-access brokerage

The interesting actor is rarely the loudest one.

> Betweenness and Burt's constraint find the broker whose removal disconnects two crews — a different answer from the top two by centrality.

GRAPH · ANALYSIS · ACH · REPORT

Business email compromise

A finance team paid the wrong account. You have the mail, a phishing page and a phone call.

> The Received chain is trustworthy inwards only. The spoofed caller ID never touches the carrier's attestation.

DECEPTION · EVIDENCE · GRAPH · REPORT

Fraud and mule networks

The transactions are the easy part.

> The social layer above them — who recruited whom, which guarantor turns up in unrelated disputes — is what the sociogram is for.

GRAPH · FEEDS · ANALYSIS · LIFECYCLE

09 — A SESSION, START TO FINISH

01

Open a case

A legal basis, a retention date, a review date and a TLP classification. Every element inside inherits that floor.

02

Put in what you have

Paste, upload, drop in a contact block, attach a .eml. Extraction raises proposals; it does not touch the graph.

03

Triage

Accept, reject or defer, keyboard-driven. An acceptance writes an assertion with the machine's rationale.

04

Look at the shape

Choose a projection, run the metrics, drag the timeline to see what was believed last month.

05

Test your explanation

Score the competing hypotheses. The ones that did not survive go in the report beside the one that did.

06

Release it

Build at a target classification, then pass the egress gate — which records the decision either way.

10 — THE RULES THAT HOLD THE WIRING TOGETHER

Six of the twelve invariants.

01 Nothing is a fact

Deferred constraint triggers on node and edge, so it holds against any write path — including a mistaken one.

03 Machines propose, analysts dispose

The proposal store holds no writer. There is no code path from an extractor to the graph.

04 Inferred edges stay distinct

Dashed on the canvas, and out of the metrics unless a projection opts in.

08 TLP gates egress

One function, called by export, SMTP, Jira and webhooks alike, so no per-integration copy can drift.

09 Durable identifiers, not displayed ones

Tox indexes the 64-hex key because the nospam rotates; Telegram the numeric id, because usernames are recycled.

11 Ingest keys are write-only

A CHECK constraint says so. A leaked ingest key means junk data, never the case file.

11 — CAPABILITY IS NOT AUTHORISATION

Five blocking items, none of them a software problem.

The build refuses several operations until an operator declares a policy — and a declaration is a string this software stores, not a fact it verifies. A false or absent declaration produces a working system and an unlawful deployment, and the difference is invisible from inside the code.

L1

Prohibited content

A store that ingests attacker-supplied binaries needs a preservation-versus-destruction policy written with counsel.

L2

Bulk victim data

Stealer logs holding data on thousands of uninvolved people. Ninety days is a placeholder somebody typed.

L3

Covert personas

Accessing a system with credentials registered under a false identity engages computer-misuse law in several jurisdictions.

L4

Message capture

Interception law, one-versus two-party consent, and third parties' content in group channels.

L5

Phishing capture

Fetching attacker infrastructure — and separately, entering any input into a phishing page, including canary credentials.

A link chart is a picture of what somebody believed. This is a case file that survives disclosure.

Ask any node on the chart why you say that, and you get a chain back to a WORM-locked exhibit with an unbroken custody log.

Reviewed adversarially eight times. Every pass found a real defect. Assume the ninth would too.